

Threat Intelligence & Indicatori di Compromissione

Analisi di una cattura di rete con Wireshark

Identificazione degli IOC in una cattura di traffico, formulazione di ipotesi sui vettori di attacco e definizione delle contromisure, con riproduzione pratica dell'attacco in laboratorio.

Percorso

Cyber Security &
Ethical Hacking

Modulo

Threat
Intelligence &
IOC

Strumenti

Wireshark · Nmap
· Kali Linux

Finalità

Documento
didattico

CONTENUTI

1.	Sintesi	1
2.	Introduzione: Threat Intelligence e IOC	2
3.	Ambiente e metodologia di analisi	2
4.	Identificazione e analisi degli IOC	3
5.	Ipotesi sui vettori di attacco	5
6.	Contromisure consigliate	6
7.	Riproduzione pratica in laboratorio	7
8.	Conclusioni	8

1. Sintesi

L'analisi della cattura di rete evidenzia un chiaro **Indicatore di Compromissione**: una **scansione delle porte TCP** condotta da un host contro un secondo host della stessa rete. Questa è la tipica attività di *ricognizione* (reconnaissance) che precede un attacco vero e proprio.

In pochi decimi di secondo l'attaccante ha sondato le prime 1024 porte del bersaglio, individuandone **12 aperte** corrispondenti a servizi noti e storicamente vulnerabili (FTP, Telnet, SMB, r-services, HTTP e altri). Il bersaglio è stato identificato come una macchina **Metasploitable 2**, un sistema volutamente vulnerabile. Sulla base dei servizi esposti, il report formula ipotesi concrete sui vettori di attacco più probabili (dal backdoor di vsftpd all'esecuzione di codice remoto via Samba) e propone contromisure immediate e strutturali per ridurre la superficie d'attacco e rilevare tempestivamente scansioni future.

2. Introduzione: Threat Intelligence e IOC

La **Threat Intelligence** è la raccolta e l'analisi di informazioni sulle minacce informatiche allo scopo di anticiparle e contrastarle. Uno dei suoi strumenti fondamentali sono gli **Indicatori di Compromissione** (IOC, *Indicators of Compromise*): tracce osservabili che segnalano un attacco in corso o già avvenuto.

NOTA PER GLI STUDENTI · CHE COS'È UN IOC

Un IOC è un "indizio" tecnico lasciato da un'attività malevola. Esempi tipici: un indirizzo IP che genera traffico anomalo, un hash di un file malevolo, un dominio usato per il comando e controllo, oppure — come in questo caso — un **pattern di traffico** incompatibile con il normale utilizzo della rete. Riconoscere un IOC significa individuare l'attacco prima che produca danni.

Nell'esercizio viene fornita una cattura di traffico realizzata con **Wireshark** (formato `.pcapng`). L'obiettivo è tripartito, secondo la traccia:

- identificare ed analizzare eventuali IOC, ovvero evidenze di attacchi in corso;
- formulare ipotesi sui potenziali **vettori di attacco** utilizzati;
- consigliare azioni per ridurre l'impatto dell'attacco attuale e di attacchi simili futuri.

Per rendere l'analisi verificabile, l'attacco è stato inoltre **riprodotto in un laboratorio controllato** (macchine virtuali Kali Linux e Metasploitable), ottenendo risultati identici a quelli della cattura fornita. Gli screenshot di questa riproduzione sono riportati come evidenze nelle sezioni seguenti.

3. Ambiente e metodologia di analisi

La cattura contiene traffico scambiato tra due soli host, entrambi macchine virtuali. Il ruolo di ciascun host si deduce dalla direzione e dal tipo di pacchetti: chi invia migliaia di richieste di connessione è l'**attaccante**; chi le riceve e risponde è la **vittima**.

Ruolo	Indirizzo IP	Descrizione
Attaccante	192.168.11.100	Kali Linux — origine della scansione
Vittima	192.168.11.112	Metasploitable 2 — bersaglio della scansione

Gli indirizzi si riferiscono alla riproduzione in laboratorio documentata in questo report. Nella cattura fornita con l'esercizio gli host erano `192.168.200.100` (attaccante) e `192.168.200.150` (vittima); il comportamento osservato è il medesimo.

Come leggere una scansione in Wireshark

Per isolare le evidenze dell'attacco all'interno delle migliaia di pacchetti catturati si utilizzano i **filtri di visualizzazione** di Wireshark. Quelli impiegati in questa analisi sono:

- `tcp.flags.syn == 1 && tcp.flags.ack == 1` — isola le risposte **SYN/ACK**, cioè le **porte aperte**;
- `tcp.flags.reset == 1` — isola i pacchetti **RST**, tipici delle **porte chiuse**;
- `tcp.flags.syn == 1 && tcp.flags.ack == 0` — mostra tutti i **SYN** inviati dall'attaccante (la scansione stessa).

4. Identificazione e analisi degli IOC

L'IOC principale è una **scansione delle porte TCP** di tipo *TCP connect scan* (Nmap `-sT`), diretta dall'attaccante verso la vittima.

Le evidenze quantitative estratte dalla cattura sono inequivocabili: l'attaccante invia **1024 pacchetti SYN** verso **1024 porte diverse** (l'intero intervallo `1-1024`, le cosiddette *well-known ports*), il tutto in una frazione di secondo. Un simile volume di richieste di connessione, verso centinaia di porte differenti e in tempi così brevi, non è compatibile con alcun uso legittimo: è la firma di uno strumento automatico di scansione.

CONCETTO CHIAVE · IL THREE-WAY HANDSHAKE COME "SONDA"

Ogni connessione TCP si apre con una stretta di mano a tre vie: `SYN → SYN/ACK → ACK`. Uno scanner sfrutta proprio questo meccanismo per capire se una porta è aperta o chiusa, osservando *come* risponde il bersaglio. Il comportamento cambia in base allo stato della porta, come illustrato di seguito.

Porta chiusa (es. 443)

- `SYN` l'attaccante bussa
- ← `RST / ACK` la vittima rifiuta

Nessun servizio in ascolto: la porta è chiusa.

Porta aperta (es. 80)

- `SYN` l'attaccante bussa
- ← `SYN / ACK` la vittima accetta
- `ACK` connessione stabilita
- `RST / ACK` chiusa subito

Servizio presente: la porta è aperta.

Perché è un *connect scan*? Sulle porte aperte la stretta di mano viene **completata** (compare l'`ACK`) e solo dopo la connessione viene chiusa con un `RST`. Questo distingue il *connect scan* (`-sT`) dal *SYN scan* (`-sS`), che invece invierebbe il `RST` senza mai completare l'handshake.

Evidenza 1 — le porte aperte (risposte SYN/ACK)

Applicando il filtro sulle risposte SYN/ACK, Wireshark mostra **12 pacchetti**: sono le 12 porte che rispondono positivamente e risultano quindi aperte.

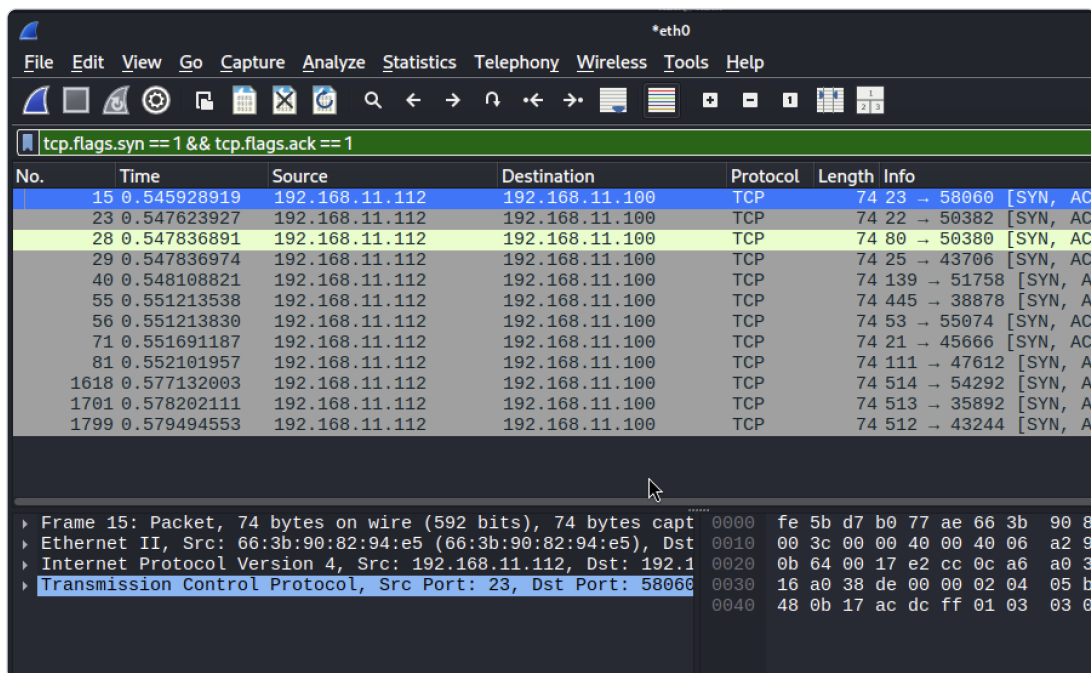


Figura 1. Filtro `tcp.flags.syn == 1 && tcp.flags.ack == 1`. Le risposte provengono dalla vittima `192.168.11.112` verso l'attaccante `192.168.11.100`. Si contano esattamente **12 porte aperte** (Displayed: 12).

Evidenza 2 — le porte chiuse (risposte RST)

Il filtro sui pacchetti di reset mostra invece un vero e proprio "muro" di risposte RST/ACK: la colorazione rossa di Wireshark rende immediatamente visibile la scansione in corso.

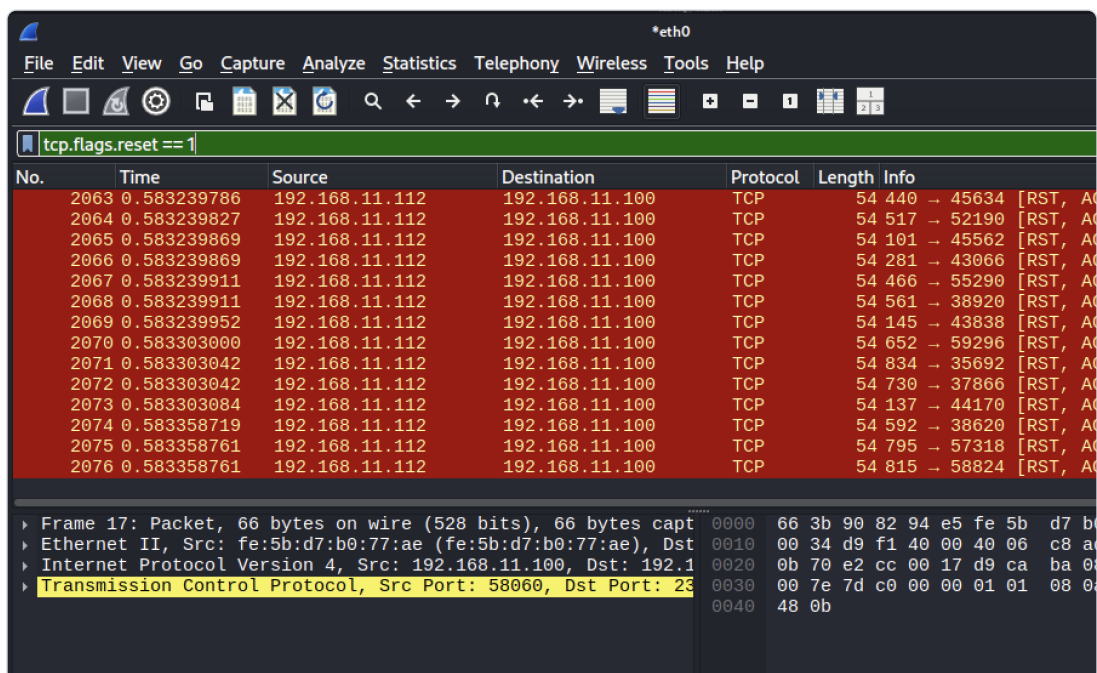


Figura 2. Filtro `tcp.flags.reset == 1`. Il flusso di pacchetti `RST, ACK` in pochi millisecondi è l'evidenza visiva della scansione. Wireshark ne mostra **1024** (Displayed: 1024).

DETTAGLIO DA CAPIRE · PERCHÉ 1024 RESET E NON 1012?

Nmap riporta 1012 porte chiuse, ma il filtro RST mostra 1024 pacchetti: la differenza è esattamente 12, cioè il numero delle porte aperte. Il motivo è che in un *connect scan* **ogni** porta genera un RST, ma per ragioni diverse:

- le **1012 porte chiuse** rispondono con un RST che parte dalla **vittima**;
- le **12 porte aperte**, dopo aver completato l'handshake, vengono chiuse con un RST che parte dall'**attaccante**.

1012 (dalla vittima) + 12 (dall'attaccante) = **1024**. Aggiungendo al filtro `&& ip.src == 192.168.11.100` si isolano i 12 reset dell'attaccante; con `ip.src == 192.168.11.112` i 1012 della vittima.

Le 12 porte aperte individuate

Le porte aperte, con i relativi servizi, sono elencate nella tabella seguente. Il loro insieme è la "impronta" (fingerprint) tipica di una macchina **Metasploitable 2**.

Porta	Servizio	Funzione
21/tcp	FTP	Trasferimento file
22/tcp	SSH	Accesso remoto cifrato
23/tcp	Telnet	Accesso remoto in chiaro
25/tcp	SMTP	Posta elettronica
53/tcp	DNS (domain)	Risoluzione dei nomi
80/tcp	HTTP	Server web
111/tcp	rpcbind	Portmapper RPC / NFS
139/tcp	NetBIOS-SSN	Condivisione file (SMB)
445/tcp	microsoft-ds	Condivisione file (SMB/Samba)
512/tcp	exec	r-service: esecuzione remota
513/tcp	login	r-service: rlogin
514/tcp	shell	r-service: rsh

IOC AGGIUNTIVO · IDENTIFICAZIONE DEL BERSAGLIO

Nella cattura fornita con l'esercizio è presente, in apertura, un annuncio **NetBIOS Host Announcement** in broadcast con cui la vittima si presenta con l'hostname **METASPLOITABLE**. È un ulteriore indicatore: rivela apertamente la natura del sistema. La riproduzione in laboratorio conferma l'identificazione, poiché il bersaglio espone le stesse identiche 12 porte, l'impronta caratteristica di Metasploitable 2.

5. Ipotesi sui vettori di attacco

Le porte aperte indicano le "porte d'ingresso" che l'attaccante prenderà di mira dopo la ricognizione. Ciascuno di questi servizi, nella versione presente su Metasploitable 2, è associato a vulnerabilità note. La tabella riassume i vettori di attacco più probabili.

Servizio	Vettore di attacco ipotizzato	Esito potenziale
FTP (21)	Backdoor di <i>vsftpd</i> 2.3.4 (CVE-2011-2523)	Shell di root remota
Telnet (23)	Credenziali trasmesse in chiaro; login di default (<i>msfadmin</i>)	Accesso e sniffing credenziali
SSH (22)	Credenziali deboli/di default; attacco a forza bruta	Accesso remoto autenticato
SMB (139/445)	Samba <i>usermap_script</i> (CVE-2007-2447), command injection	Esecuzione codice come root
r-services (512/513/514)	Autenticazione basata sulla "fiducia" tra host (rsh/rlogin/rexec)	Shell senza password
HTTP (80)	Web app vulnerabili (DVWA, Mutillidae, phpMyAdmin): SQL injection, upload, RCE	Compromissione dell'applicazione
SMTP (25)	Enumerazione utenti (comando <i>VRFY</i>); relay aperto	Ricognizione / abuso del mail server
RPC/DNS (111/53)	Enumerazione NFS/RPC; interrogazione del servizio DNS	Raccolta informazioni / pivot

SEQUENZA TIPICA DELL'ATTACCO

Il vettore complessivo è: **scansione automatizzata** → **identificazione dei servizi legacy insicuri** → **sfruttamento di una vulnerabilità nota** (con ogni probabilità Samba, vsftpd o gli r-services) per ottenere accesso remoto, tipicamente con privilegi di **root**. Poiché la scansione si è fermata a 1024, un passo successivo prevedibile è una scansione completa (*-p-*) per scoprire gli altri servizi vulnerabili oltre tale soglia.

6. Contromisure consigliate

La scansione, di per sé, è **ricognizione** e non ancora compromissione: rappresenta quindi un campanello d'allarme che consente di intervenire *prima* dello sfruttamento. Le azioni si distinguono in immediate e strutturali.

Azioni immediate (ridurre l'impatto attuale)

- **Isolare e bloccare** l'host che effettua la scansione (*192.168.11.100*) a livello di firewall e verificare se l'attività è autorizzata.
- **Mettere in quarantena il bersaglio**: un sistema con questo profilo (Metasploitable) va rimosso dalla rete o isolato immediatamente in un ambiente reale.
- **Disattivare i servizi non necessari** — in particolare Telnet, FTP e gli r-services (512/513/514), causa diretta dell'enorme superficie esposta.

Azioni strutturali (prevenire attacchi futuri)

- **Firewall in *default-deny* e segmentazione di rete**: esporre solo le porte strettamente necessarie.

- **Dismettere i protocolli legacy insicuri:** Telnet → SSH; rsh/rlogin/rexec → rimossi; FTP → SFTP/FTPS.
- **IDS/IPS** (Snort o Suricata) con regole di rilevamento delle scansioni, oltre a *rate-limiting* delle connessioni e `fail2ban` contro gli attacchi a forza bruta.
- **Patch management** e *vulnerability scanning* periodici: i servizi in ascolto vanno aggiornati o eliminati.
- **Logging e alerting** su pattern anomali (molti RST in pochi secondi, molte connessioni verso porte diverse dallo stesso IP), così da rilevare tempestivamente una scansione.

7. Riproduzione pratica in laboratorio

Per verificare l'analisi, l'attacco è stato riprodotto in un laboratorio isolato con due macchine virtuali: **Kali Linux** (attaccante) e **Metasploitable 2** (vittima), collegate alla stessa rete privata (Host-Only / Internal), in modo da non generare traffico verso l'esterno.

Procedura

1. Avviare le due VM sulla stessa rete isolata e verificarne la raggiungibilità con `ping`; annotare gli IP con `ip a`.
2. Su Kali, avviare la cattura in **Wireshark** sull'interfaccia collegata a quella rete (qui `eth0`).
3. Da un terminale, lanciare la scansione — è questo il comando che genera l'IOC:
`nmap -sT -p 1-1024 192.168.11.112`
dove `-sT` indica il *connect scan* e `-p 1-1024` limita l'analisi alle well-known ports.
4. Fermare la cattura e applicare i filtri di visualizzazione per isolare porte aperte e chiuse (Figure 1 e 2); salvare il file in formato `.pcapng`.

L'output di Nmap conferma il risultato dell'analisi: 12 porte aperte e 1012 chiuse, con la scansione completata in appena 0,61 secondi.

```
(kali@kali)-[~]
$ nmap -sT -p 1-1024 192.168.11.112
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-07 09:38 -0400
Nmap scan report for 192.168.11.112
Host is up (0.0016s latency).
Not shown: 1012 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 66:3B:90:82:94:E5 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.61 seconds
```

Figura 3. Output di `nmap -sT -p 1-1024 192.168.11.112`. Sono elencate le 12 porte aperte (ftp, ssh, telnet, smtp, domain, http, rpcbind, netbios-ssn, microsoft-ds, exec, login, shell); "Not shown: 1012 closed tcp ports". I 12 + 1012 = 1024 pacchetti RST della Figura 2 trovano qui la loro spiegazione.

NOTA TECNICA · GLI INDIRIZZI MAC

Nella cattura di riproduzione gli indirizzi MAC (`fe:5b:...` e `66:3b:...`) sono di tipo *locally-administered* perché generati dall'hypervisor UTM/QEMU su macOS; nella cattura originale dell'esercizio erano invece del tipo `08:00:27:...`, caratteristici di VirtualBox. La differenza non ha alcun impatto sull'analisi.

8. Conclusioni

La cattura documenta con chiarezza la **fase di ricognizione** di un attacco: una scansione TCP connect dell'intervallo di porte 1–1024, che ha rivelato 12 servizi aperti su una macchina Metasploitable 2. Riconoscere questo IOC — un volume anomalo di SYN e un "muro" di RST in tempi brevissimi — permette di intervenire prima che la vulnerabilità venga sfruttata.

Le contromisure più efficaci agiscono sulla **causa** del problema, cioè l'eccessiva superficie d'attacco: chiusura dei servizi legacy insicuri, firewall in default-deny, segmentazione e monitoraggio continuo tramite IDS/IPS. Come ricorda la buona prassi, la sicurezza non è un prodotto ma un **processo continuo**: la capacità di rilevare tempestivamente la ricognizione è spesso ciò che distingue un incidente sventato da una compromissione riuscita.

Documento redatto a fini didattici nell'ambito del percorso Cyber Security & Ethical Hacking — modulo Threat Intelligence & IOC. Le attività descritte sono state svolte in un laboratorio isolato su sistemi di proprietà, a scopo esclusivamente formativo.